



Weekly IT Security Brief (Official-source-first) | 2026-09-27 06:00

Formatted for readability · Auto-generated



Weekly Summary

- Priority snapshot: 5 KEV-listed vulnerabilities are actively exploited in the wild (top 8 shown in this brief).
- Urgent patch focus: CVE-2026-67279(2026-09-28), CVE-2026-65660(2026-09-28), CVE-2026-87902(2026-09-28). Prioritize internet-facing and privileged systems first.
- Threat trend #1: Storm-3168: Agentic-driven cloud attacks using compromised service principals. Microsoft details JADEPUFFER-linked Azure reconnaissance, resource deletion, and credential access using compromised service principals, identifying the activity a...
- Threat trend #2: Beyond the ransomware: Tracking Storm-2570's consistent tradecraft across deployments. Storm-2570 is a ransomware affiliate that uses consistent post-compromise tools and techniques across deployments involving Qilin, DragonForce, Anubis, and...
- Recommended action this week: patch KEV/high-risk exposed services within 24 hours and tighten monitoring for anomalous login, command execution, and credential access patterns.



Report A: CVE Deep Dive (CISA KEV + NVD)

CVE-2026-67279

CVE Title	CVE-2026-67279 mikrotik/routeros Unknown Type
CVE Description	RouterOS SSH enters the connection protocol after a client-requested rekey even though user authentication was never attempted, allowing an unauthenticated client to open a session channel and send an exec request. On affected builds the server dispatches the command, enabling unauthenticated creation, overwrite, and reconstruction of files in the RouterOS managed file namespace, including support files containing c...
Root Cause	Authentication workflow has logical flaws allowing bypass.
Exploitation Prerequisite	Target service is network-reachable and accepts attacker-crafted unauthorized requests.
Exploit Path	Unauthorized request -> auth bypass -> sensitive data access / privileged operations.
Affected Products	mikrotik/routeros
Risk Score	6.5 (MEDIUM)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-09-28
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-67279

CVE-2026-65660

CVE Title	CVE-2026-65660 microsoft/sharepoint_server Unknown Type
CVE Description	Improper control of generation of code ('code injection') in Microsoft Office SharePoint allows an authorized attacker to execute code over a network.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	microsoft/sharepoint_server
Risk Score	8.8 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-09-28
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-65660

CVE-2026-87902

CVE Title	CVE-2026-87902 待核實 Unknown Type
CVE Description	An unauthenticated attacker can make `get_page_template()` page-template resolution include a chosen readable local `.php` file outside the active theme directories. If relevant pre-conditions for both the server and the active theme are met, this can lead to RCE.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	待核實
Risk Score	8.1 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-09-28
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-87902

CVE-2026-5430

CVE Title	CVE-2026-5430 wso2/api_control_plane Unknown Type
CVE Description	The JWT authentication mechanism accepts tokens signed with algorithms other than those explicitly configured or supported. This allows an attacker to craft a JWT with an unsupported algorithm, which is then incorrectly validated, leading to unauthorized access.
Root Cause	Authentication workflow has logical flaws allowing bypass.
Exploitation Prerequisite	Target service is network-reachable and accepts attacker-crafted unauthorized requests.
Exploit Path	Unauthorized request -> auth bypass -> sensitive data access / privileged operations.
Affected Products	wso2/api_control_plane, wso2/api_manager, wso2/traffic_manager, wso2/universal_gateway
Risk Score	10.0 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-09-27
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-5430

CVE-2026-71362

CVE Title	CVE-2026-71362 adobe/commerce Privilege Escalation
CVE Description	Adobe Commerce is affected by an Incorrect Authorization vulnerability that could result in privilege escalation. An attacker could leverage this vulnerability to gain elevated access to sensitive resources. Exploitation of this issue does not require user interaction.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	adobe/commerce, adobe/commerce_b2b, adobe/magento
Risk Score	9.1 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-09-27
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-71362



Report A2: Newly Published CVEs (NVD, last 7 days)

CVE-2026-93954

CVE Title	CVE-2026-93954 待核實 Unknown Type
CVE Description	A security vulnerability has been detected in grimmory-tools grimmory up to 3.3.3/3.4.1. Affected is the function AppSettingController.getAppSettings of the file backend/src/main/java/org/booklore/controller/AppSettingController.java of the component Settings API Endpoint. Such manipulation leads to incorrect authorization. The attack can be launched remotely. The exploit has been disclosed publicly and may be used....
Affected Products	待核實
Risk Score	4.3 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-93954

CVE-2026-89155

CVE Title	CVE-2026-89155 待核實 Unknown Type
CVE Description	Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
Affected Products	待核實
Risk Score	待核實 (待核實)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-89155

CVE-2026-93955

CVE Title	CVE-2026-93955 待核實 Unknown Type
CVE Description	A vulnerability was detected in grimmory-tools grimmory up to 3.3.3/3.4.1. Affected by this vulnerability is the function streamFileToResponse of the file backend/src/main/java/org/booklore/controller/KoboController.java of the component Download Endpoint. Performing a manipulation of the argument bookId results in authorization bypass. The attack may be initiated remotely. The exploit is now public and may be used....
Affected Products	待核實
Risk Score	4.3 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-93955

CVE-2026-93956

CVE Title	CVE-2026-93956 待核實 XSS
CVE Description	A flaw has been found in olivier-ls PHP-FTS up to 1.1.2. Affected by this issue is the function SearchEngine::buildHighlights of the file src/SearchEngine.php of the component Search Engine. Executing a manipulation of the argument Query can lead to cross site scripting. The attack may be launched remotely. The exploit has been published and may be used. Upgrading to version 1.1.3 can resolve this issue. This patch...
Affected Products	待核實
Risk Score	3.5 (LOW)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-93956



Report B: Threat Intelligence News (last 7 days)

Headline: Storm-3168: Agentic-driven cloud attacks using compromised service principals

Source	Microsoft Security Blog
Published	Fri, 25 Sep 2026 15:35:08 +0000
Key Takeaway	Microsoft details JADEPUFFER-linked Azure reconnaissance, resource deletion, and credential access using compromised service principals, identifying the activity as associated with Storm-3168 and providing guidance for defenders. The post Storm-3168: Agentic-driven cloud attacks using compromised se Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	cloud/待核實
Technique	Credential Access
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/09/25/storm-3168-agentic-driven-cloud-attacks-using-compromised-service-principals/

Headline: Beyond the ransomware: Tracking Storm-2570’s consistent tradecraft across deployments

Source	Microsoft Security Blog
Published	Thu, 24 Sep 2026 16:00:00 +0000
Key Takeaway	Storm-2570 is a ransomware affiliate that uses consistent post-compromise tools and techniques across deployments involving Qilin, DragonForce, Anubis, and BERT ransomware, and provides guidance to help defenders detect and disrupt this activity before ransomware deployment. The post Beyond the rans Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	technology/待核實
Technique	Ransomware
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/09/24/beyond-ransomware-tracking-storm-2570-consistent-tradecraft-across-deployments/

Headline: CISA Whitepaper Charts Path to Establishing and Maturing CVE Program Quality

Source	CISA News
Published	Wed, 23 Sep 26 12:00:00 +0000
Key Takeaway	CISA Whitepaper Charts Path to Establishing and Maturing CVE Program Quality Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-whitepaper-charts-path-establishing-and-maturing-cve-program-quality

Headline: CISA Hosts Cyber Storm X, Nationwide Cybersecurity Exercise to Strengthen Resilience

Source	CISA News
Published	Fri, 18 Sep 26 12:00:00 +0000
Key Takeaway	CISA Hosts Cyber Storm X, Nationwide Cybersecurity Exercise to Strengthen Resilience Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-hosts-cyber-storm-x-nationwide-cybersecurity-exercise-strengthen-resilience

Headline: Trust and the enticing consultancy offer

Source	Cisco Talos Blog
Published	Thu, 24 Sep 2026 18:00:37 GMT
Key Takeaway	Hubris might be the real vulnerability that the cyber industry must worry about. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://blog.talosintelligence.com/trust-and-the-enticing-consultancy-offer/

Headline: The Closed Quorum: Inside the first reported autonomous AI C2 implant

Source	Cisco Talos Blog
Published	Tue, 22 Sep 2026 10:00:58 GMT
Key Takeaway	CLOSEDQUORUM, a malware binary discovered through Cisco Talos' CAIRN project, exhibits fully autonomous command and control (C2). It represents a shift in effort displacement for attackers, in which expanding portions of the attack chain can be executed without operator involvement. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	Malware Deployment
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://blog.talosintelligence.com/the-closed-quorum-inside-the-first-reported-autonomous-ai-c2-implant/

Headline: Lunex Stealer Abuses AMD Driver to Disable Security Monitoring and Steal Browser Credentials

Source	The Hacker News
Published	Sat, 26 Sep 2026 23:52:52 +0530
Key Takeaway	"The attack chain begins with a fake CAPTCHA page and Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	cloud/uk
Technique	Malware Deployment
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://thehackernews.com/2026/09/lunex-stealer-abuses-amd-driver-to.html

Headline: Attackers Bypass WAFs to Exploit Oracle PeopleSoft Flaw and Deploy Web Shells

Source	The Hacker News
Published	Sat, 26 Sep 2026 17:16:40 +0530
Key Takeaway	Google is warning of renewed mass exploitation of a known security vulnerability in Oracle PeopleSoft as part of a campaign targeting multiple sectors globally. The ShinyHunters-linked activity involves the weaponization of CVE-2026-35273 (CVSS score: 9.8), a critical security flaw that could result Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/global
Technique	Exploit Chain
MITRE ATT&CK	Unverified
Related CVEs	CVE-2026-35273
Link	https://thehackernews.com/2026/09/attackers-bypass-wafs-to-exploit-oracle.html

Headline: China and US Agree to Establish AI Safety Channel and Continue Trade and Military Talks

Source	SecurityWeek
Published	Sat, 26 Sep 2026 18:09:28 +0000
Key Takeaway	The US and China agreed to set up a communication mechanism for artificial intelligence-related incidents. The post China and US Agree to Establish AI Safety Channel and Continue Trade and Military Talks appeared first on SecurityWeek . Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/china-and-us-agree-to-establish-ai-safety-channel-and-continue-trade-and-military-talks/

Headline: New x47.c Windows Botnet Weaponizes xAI Grok, AI API Draining

Source	SecurityWeek
Published	Sat, 26 Sep 2026 12:00:00 +0000
Key Takeaway	The Windows botnet relies on AI to maintain persistence, using xAI Grok to choose from predefined actions. The post New x47.c Windows Botnet Weaponizes xAI Grok, AI API Draining appeared first on SecurityWeek . Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/new-x47-c-windows-botnet-weaponizes-xai-grok-ai-api-draining/

Headline: ShinyHunters uses WAF bypass trick in Oracle PeopleSoft attacks

Source BleepingComputer

Published Sat, 26 Sep 2026 15:03:34 -0400

Key Takeaway The ShinyHunters extortion gang is using a URL-encoding trick to bypass web application firewall rules that mitigate the Oracle PeopleSoft CVE-2026-35273 flaw, allowing the threat actors to resume widespread exploitation of a flaw on vulnerable servers. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target unknown-target

Technique Exploit Chain

MITRE ATT&CK Unverified

Related CVEs CVE-2026-35273

Link <https://www.bleepingcomputer.com/news/security/shinyhunters-uses-waf-bypass-trick-in-oracle-peoplesoft-attacks/>

Headline: Claude Opus 5.5 uses 95% fewer em dashes, but its answers are getting longer

Source	BleepingComputer
Published	Sat, 26 Sep 2026 12:26:58 -0400
Key Takeaway	Anthropic's Claude Opus 5.5 appears to be changing how it writes, with new analysis showing fewer obvious AI writing patterns, shorter sentences, and simpler wording compared with Opus 5. [...] Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.bleepingcomputer.com/news/artificial-intelligence/claude-opus-55-uses-95-percent-fewer-em-dashes-but-its-answers-are-getting-longer/

Sources (official/authoritative first)

<https://www.cisa.gov/known-exploited-vulnerabilities-catalog>

<https://nvd.nist.gov/>

<https://www.cve.org/>

[**https://attack.mitre.org/**](https://attack.mitre.org/)

[**https://www.microsoft.com/en-us/security/blog/**](https://www.microsoft.com/en-us/security/blog/)

[**https://www.cisa.gov/news-events/cybersecurity-advisories**](https://www.cisa.gov/news-events/cybersecurity-advisories)

[**https://www.mandiant.com/resources**](https://www.mandiant.com/resources)

[**https://blog.talosintelligence.com/**](https://blog.talosintelligence.com/)